



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Malicious JetBrains Plugins Steal AI API Keys as Chrome Extensions Capture Chatbot Chats

Malware Analysis Report

Classification	TLP:CLEAR
Published	2026-06-17
Version	1.0
Author	Lost Boys Cyber
Report Type	Malware Analysis Report

TLP:CLEAR | Lost Boys Cyber | Malicious JetBrains Plugins Steal AI API Keys as Chrome Extensions Capture Chatbot Chats - Malware Analysis Report

Published: 2026-06-17 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Sample Metadata
3. Source Review & Confidence
4. Initial Triage and Delivery Assessment
5. Static Analysis
6. Code Analysis
7. Dynamic Analysis
8. Process Tree and Execution Chain
9. Persistence and System Modification
10. Network and Infrastructure Analysis
11. Indicators of Compromise
12. MITRE ATT&CK Mapping
13. Detection Engineering
14. Threat Hunting
15. Triage and Incident Response
16. Validation and Emulation
17. Recommendations
18. References and Refresh Notes

Malicious JetBrains Plugins Steal AI API Keys as Chrome Extensions Capture Chatbot Chats

1. Executive Summary

Lost Boys Cyber assesses with medium confidence that the reported JetBrains Marketplace activity is a developer-supply-chain credential-theft campaign rather than a conventional endpoint malware outbreak. Aikido Security and subsequent public reporting identified at least 15 malicious JetBrains IDE plugins across seven vendor accounts. The plugins presented themselves as AI coding assistants for chat, commit messages, code review, bug finding, and unit-test generation while covertly exfiltrating user-entered AI provider API keys.

The primary victim population is software developers and engineering teams using JetBrains IDEs with third-party AI-assistant plugins. The stolen credentials reportedly include OpenAI, DeepSeek, and SiliconFlow API keys entered into plugin settings. The campaign matters because developer workstations routinely hold source code, cloud credentials, signing material, CI/CD access, and paid AI-provider keys. A compromised IDE plugin can therefore become both a credential-theft mechanism and an intrusion lead into software delivery environments.

Public reporting states that the plugins remained functional, which reduces user suspicion, and that the operator also ran a paid tier in which the server returned an AI-provider key to the client after payment. Lost Boys Cyber assesses that this creates a credible LLMjacking monetization path: collect real users' paid AI keys, resell or broker access through the plugin ecosystem, and shift API usage cost to victims. No original plugin archive, source package, or sandbox telemetry was provided to Lost Boys Cyber; this report is source-backed and clearly separates reported facts from defensive assessment.

The same public source also summarized a separate browser-extension exposure named PromptSnatcher in which two Chrome ad-blocking extensions captured private conversations with AI chatbots. This report treats the Chrome-extension component as adjacent AI-data-exposure context, not as the same malware family as the JetBrains plugins. Immediate defender actions are to inventory JetBrains plugins, remove the listed plugins, revoke and rotate AI-provider API keys entered into IDE extensions, review AI-provider billing and usage logs for abuse, inspect developer endpoints for plugin artifacts and HTTP egress to 39.107.60[.]51, and harden extension/plugin approval workflows.

Finding	Analyst Assessment	Defensive Implication
Fifteen JetBrains Marketplace plugins with common hidden behavior	High-confidence source-reported campaign detail	Treat exposed developer workstations as credential-theft leads and not merely unwanted-plugin cleanup
Exfiltration of API keys over plaintext HTTP to 39.107.60[.]51	High-confidence reported infrastructure detail	Inspect proxy/DNS/EDR telemetry for direct or application-origin HTTP egress from JetBrains IDE processes
Functional AI-assistant features retained	Medium-confidence tradecraft assessment	User trust and marketplace install counts are insufficient safety signals
Paid tier returns API keys from server to plugin client	Medium-confidence monetization assessment	Review AI-provider billing for unusual usage and assume stolen keys may have been resold or shared
Chrome ad blockers capture AI chats under PromptSnatcher reporting	Adjacent source-reported AI-data exposure	Apply the same extension-governance lens to browser extensions that can read AI-chat sessions

2. Sample Metadata

No original malware sample was supplied to Lost Boys Cyber. Metadata below reflects publicly reported plugin/package identifiers and infrastructure, not locally verified hashes.

Field	Value
Family / Cluster	Malicious JetBrains AI-assistant plugin cluster; no vendor family name published
Malware Type	IDE plugin credential stealer / developer supply-chain malware
Platform	JetBrains IDE ecosystem; adjacent PromptSnatcher activity affects Google Chrome extensions
Primary Sample SHA256	Not available in public reporting reviewed for this task
Additional Hashes	Not available; plugin IDs and package IDs are the primary observables
File Type / Format	JetBrains IDE plugin packages; likely JVM/Kotlin/Java plugin code based on JetBrains ecosystem, but binary internals were not independently inspected
Delivery Theme	AI coding assistant, DeepSeek/OpenAI/SiliconFlow-backed code review, commit-message, bug-finding, and unit-test automation
First Seen / Reported	Activity reportedly ongoing since late October 2025; new plugins released as recently as 2026-06-10; public reporting published 2026-06-17
Analyst Confidence	Medium overall; high for source-reported plugin names, API-key-theft behavior, and destination IP; medium for monetization and campaign-scale interpretation
Primary Objective	Theft and monetization of AI-provider API keys; possible downstream exposure of developer environments
Source Basis	Aikido Security research as summarized by The Hacker News, BleepingComputer, Hackread, CyberPress, and related public coverage

Reported malicious JetBrains plugins:

Plugin Name	Plugin / Package ID	Reported Role
DeepSeek Junit Test	org.sm.yms.toolkit	AI unit-test assistant lure
DeepSeek Git Commit	com.json.simple.kit	AI commit-message assistant lure
DeepSeek FindBugs	org.bug.find.tools	AI bug-finding assistant lure
DeepSeek AI Chat	org.translate.ai.simple	AI chat assistant lure
DeepSeek Dev AI	com.yy.test.ai.simple	AI development assistant lure
DeepSeek AI Coding	com.dev.ai.toolkit	AI coding assistant lure
AI FindBugs	com.json.view.simple	AI bug-finding assistant lure
AI Git Commitor	com.my.git.ai.kit	AI commit assistant lure
AI Coder Review	org.check.ai.ds	AI code-review assistant lure

DeepSeek Coder AI	com.review.tool.code	AI coding assistant lure
AI Coder Assistant	org.code.assist.dev.tool	AI coding assistant lure
DeepSeek Code Review	com.coder.ai.dpt	AI code-review assistant lure
CodeGPT AI Assistant	com.my.code.tools	AI assistant lure; reportedly exceeded 25,000 downloads
DeepSeek AI Assist	ord.cp.code.ai.kit	AI assistant lure; reportedly exceeded 25,000 downloads
Coding Simple Tool	com.dp.git.ai.tool	AI/simple coding utility lure

3. Source Review & Confidence

Source	Contribution	Confidence	Notes
Aikido Security research, Multiple JetBrains IDE plugins caught stealing AI keys	Primary source for plugin count, vendor-account count, hidden exfiltration behavior, destination IP, provider scope, and monetization observation	High for reported observations; medium for broader intent	Primary source was not directly extractable by the current tool path, but multiple search and media summaries quote the same findings
The Hacker News, Malicious JetBrains Plugins Steal AI API Keys as Chrome Extensions Capture Chatbot Chats	Intake source and article text used for plugin list, dates, exfiltration description, and PromptSnatcher context	Medium-to-high	Secondary media summary citing Aikido Security and Jean-Marie R.; suitable for intake validation
BleepingComputer / Hackread / CyberPress / Infosecurity Magazine coverage	Corroborates high-level campaign scope, install count, and affected providers	Medium	Used for triangulation through search-result summaries; not treated as independent reverse engineering
Lost Boys Cyber analytic synthesis	Detection, hunting, response, and governance recommendations	Medium	Derived from cited facts plus standard developer-workstation telemetry and extension-governance controls

Directly reported evidence includes the existence of at least 15 plugins, seven vendor accounts, a shared hidden behavior of exfiltrating API keys entered into settings, support for OpenAI, DeepSeek, and SiliconFlow keys, plaintext HTTP exfiltration to 39.107.60[.]51, activity dating back to late October 2025, and new plugin releases as recently as 2026-06-10.

High-confidence assessment: the campaign deliberately targets trusted developer workflows by delivering functional tools that ask users for long-lived API credentials. Marketplace listing legitimacy, large install counts, and working AI-assistant functionality should not be treated as proof of benign behavior.

Lower-confidence inference: exact operator identity, total number of compromised organizations, whether install counts were inflated, whether stolen AI keys were sold to other criminal actors, and the complete source-code structure of each plugin remain unverified by Lost Boys Cyber due to lack of raw packages.

4. Initial Triage and Delivery Assessment

The delivery channel is the JetBrains Marketplace rather than email attachment, exploit kit, or drive-by download. The campaign relies on user installation of IDE plugins that appear to provide useful AI development features. This is a software-supply-chain and marketplace-trust problem: the initial access decision is made by a developer who wants productivity gains inside a trusted IDE.

The lure is credible because the advertised features match real developer demand: chatbot assistance, test generation, commit-message drafting, code review, and bug finding. The plugins reportedly require the user to open a settings panel and enter an AI-provider key. That credential-entry step is both normal for legitimate AI tools and the point at which the malicious behavior triggers.

Variant / Artefact	Delivery Role	Notes
JetBrains Marketplace plugin listing	Distribution and trust anchor	Multiple listings across seven vendor accounts reduce dependence on a single publisher account
AI-assistant feature set	Social-engineering lure	Promises DeepSeek or other LLM-backed chat, code review, commits, bugs, and tests
Plugin settings panel	Credential-collection point	User enters OpenAI, DeepSeek, or SiliconFlow API key to enable advertised functionality
Functional plugin behavior	Suspicion reduction	Reporting states plugins work as advertised while adding hidden exfiltration
Plaintext HTTP request to 39.107.60[.]51	Credential exfiltration channel	High-value network observable; lack of TLS may expose credential movement in proxy captures
Paid / donation-wall tier	Monetization path	Server returns an AI key to the client after payment; may indicate resale of victim-funded API access
Chrome ad-blocker extensions	Adjacent AI-data exposure	Smart Adblocker and Adblock for Browser reportedly collect private AI-chat conversations under PromptSnatcher reporting

5.1 File and Build Characteristics

Lost Boys Cyber did not receive plugin archives for hashing, decompilation, manifest inspection, or dependency review. The static observations below are therefore inferred from source reporting and from JetBrains plugin architecture expectations.

Static Signal	Evidence	Analyst Value
Repeated plugin naming pattern	Many names combine DeepSeek, AI, coder, review, commit, JUnit, or FindBugs wording	Supports marketplace hunting for similarly themed malicious or copycat listings
Package-ID diversity	Fifteen package IDs across org.*, com.*, and ord.* namespaces	Reduces the effectiveness of single-name blocking and suggests repackaging
Settings-based API-key collection	Reporting states users enter provider keys into plugin settings	Indicates likely storage in IDE/plugin settings or local configuration before exfiltration
Shared codebase	Aikido reporting states all 15 plugins share a similar codebase	Enables YARA/source similarity checks if plugin archives are retrieved
HTTP egress to hard-coded IP	Reported destination 39.107.60[.]51	High-value indicator for proxy, firewall, and EDR network telemetry
Functional AI-provider support	OpenAI, SiliconFlow, and DeepSeek are	API-key regexes and provider billing logs

	named providers	become central triage data sources
--	-----------------	------------------------------------

5.2 Strings, Imports, and Embedded Artefacts

Without raw packages, specific class names, manifests, imports, and string tables cannot be independently validated. However, defenders retrieving plugin packages should prioritize static pivots including the literal 39.107.60.51, http:// URL construction, provider labels such as OpenAI, SiliconFlow, and DeepSeek, JetBrains settings or persistent-state classes, Java/Kotlin HTTP client usage, donation-wall logic, and plugin.xml marketplace identifiers.

5.3 Static Configuration Clues

Configuration Item	Reported / Expected Value	Confidence
Exfiltration server	39.107.60[.]51	High from source reporting
AI providers	OpenAI, SiliconFlow, DeepSeek	High from source reporting
Communication security	Plaintext HTTP for exfiltration	High from source reporting
Marketplace distribution	15 JetBrains plugins across seven vendor accounts	High from source reporting
Chrome extension IDs	iojpcjjdfhlcbgjnpngcmaojmlokmeii; jbjcocinigpbgfphlpgaidbmlngnnn	Medium-high for adjacent PromptSnatcher context

6.1 Reverse-Engineering Method

No Ghidra, radare2, JADX, CFR, FernFlower, or IntelliJ plugin decompiler workflow was run because no plugin sample was provided. The code-analysis section is therefore a source-backed analytic reconstruction and a reproducibility guide for the next analyst who obtains plugin packages.

Step	Tooling	Goal
Unpack plugin	unzip / 7z	Extract plugin.xml, JARs, resources, and embedded dependencies
Hash and inventory	sha256sum, file, strings	Preserve sample identity and basic metadata
Decompile JVM classes	CFR, FernFlower, JADX, IntelliJ built-in decompiler	Locate settings UI, credential storage, outbound HTTP, and payment logic
Search for providers and IP	strings and repository search	Identify provider field names and 39.107.60.51 references
Review plugin permissions	plugin.xml and marketplace metadata	Determine IDE APIs and compatibility surface
Dynamic detonation	Disposable JetBrains IDE profile with test API key	Confirm whether settings save triggers exfiltration and capture exact request path/body

6.2 Functions and Logic of Interest

Function / Routine	Evidence	Why It Matters
Settings save / apply handler	User must enter API key in plugin settings; API key is then exfiltrated	Likely point where malicious network request is triggered

AI request wrapper	Plugin remains functional for advertised model calls	May mix legitimate provider calls with covert exfiltration and complicate user perception
Exfiltration HTTP client	Source reports plaintext request to attacker-controlled server	Core malicious behavior and high-value detection point
Donation-wall / payment handler	Source reports server sends an API key back to paying user	Possible resale mechanism for stolen or operator-controlled keys
Provider configuration parser	Supports OpenAI, SiliconFlow, DeepSeek keys	Helps validate which secrets require rotation and billing review

6.3 Anti-Analysis, Evasion, and Obfuscation

Public reporting does not describe classic anti-debugging, sandbox evasion, packing, VM checks, or encrypted payload staging. The campaign's evasion is primarily social and ecosystem-based: publish useful tools in a trusted plugin marketplace, keep the features working, split listings across vendors, and rely on normal-looking credential entry. Defenders should not wait for obvious malware signatures; unauthorized secret transmission from a developer tool is the high-signal behavior.

7.1 Execution Overview

Expected dynamic flow: a developer installs a malicious AI-assistant plugin, opens plugin settings, enters an OpenAI/DeepSeek/SiliconFlow API key, the plugin stores or reads that key, silently transmits it to 39.107.60[.]51 over plaintext HTTP, and then continues providing advertised AI features. If the paid tier is used, the plugin server reportedly returns an AI-provider key to the client after payment.

7.2 Filesystem, Registry, Service, and Task Changes

No source reporting indicates Windows service creation, scheduled tasks, registry autoruns, macOS LaunchAgents, or Linux user services. Persistence is likely achieved through normal IDE plugin installation: once installed and enabled, the plugin loads whenever the compatible JetBrains IDE starts or when relevant plugin actions/settings execute.

Artefact Type	Likely Location / Source	Triage Notes
JetBrains plugin files	User JetBrains configuration/plugin directories; exact path varies by OS and IDE version	Inventory installed plugin IDs and compare with IOC list
IDE settings / options	JetBrains config directories	Search for provider API-key fields; handle secrets carefully and do not paste them into tickets
Marketplace metadata	Plugin ID, version, vendor account, install timestamp	Establish exposure window and whether a removed marketplace listing remains locally installed
Proxy/browser/EDR network telemetry	Host egress to 39.107.60.51	Correlate with IDE process name and plugin install timestamp

7.3 Network and Command-and-Control Behaviour

The reported network behavior is a simple credential-exfiltration request, not a full bidirectional malware C2 channel. The key detail is that exfiltration occurs to an attacker-controlled server over plaintext HTTP. This can be detected by endpoint network sensors, enterprise proxies, firewall logs, DNS logs if a domain is used in variants, and AI-provider billing anomalies.

Network Signal	Role	Confidence	Defensive Use
39.107.60[.]51	Reported attacker-controlled	High	Block, retrohunt, and correlate

	exfiltration server		with JetBrains IDE process egress
Plaintext HTTP	Reported exfiltration protocol	High	Inspect HTTP proxy logs for provider-key-shaped parameters or bodies, where lawful and privacy-approved
AI-provider API traffic	Legitimate plugin functionality	Medium	Distinguish normal OpenAI/DeepSeek/SiliconFlow calls from suspicious direct-IP exfiltration
Server returns API key after payment	Reported paid-tier behavior	Medium	Investigate whether returned keys are victim-funded credentials and review legal/privacy implications before capture

7.4 Observed Capability Summary

Capability	Supporting Dynamic Evidence
Credential theft	Source reports exfiltration of API keys entered into plugin settings
Developer-workstation targeting	Delivery through JetBrains IDE plugins and AI coding-assistant themes
Functional cover	Plugins reportedly work as advertised while stealing credentials
LLMjacking / resale enablement	Paid tier reportedly returns API keys from server to client after payment
AI-chat data exposure, adjacent activity	PromptSnatcher Chrome extensions reportedly capture non-public AI conversations and account-tier metadata

8. Process Tree and Execution Chain

For the JetBrains plugin campaign, process-tree evidence is expected to be subtle. The malicious code likely runs inside the JetBrains IDE process or plugin runtime rather than creating a separate suspicious process tree.

Step	Parent Process	Child / Action	Why It Matters
1	User shell / OS launcher	JetBrains IDE starts	Normal IDE launch loads installed plugins
2	JetBrains IDE process	Malicious plugin initializes	Plugin execution inherits trust and network access from IDE
3	JetBrains IDE process	User opens plugin settings and enters API key	Credential collection occurs through expected UI workflow
4	JetBrains IDE process	Outbound HTTP to 39.107.60[.J51	Credential exfiltration may appear as IDE network traffic, not a separate malware process
5	JetBrains IDE process	Legitimate AI-provider calls	Functional behavior can mask the malicious request among

			expected AI traffic
--	--	--	---------------------

The PromptSnatcher Chrome-extension context is analogous: the execution occurs inside the browser extension runtime, so defenders should focus on extension inventory, permissions, content-script behavior, and browser network telemetry rather than expecting a new process tree.

9. Persistence and System Modification

The reported persistence mechanism is ecosystem-native installation. A plugin installed into a JetBrains IDE profile remains present across IDE restarts until removed, disabled, or overwritten. The same is true for Chrome extensions in the adjacent PromptSnatcher activity.

Modification Type	Artefact	Evidence	Confidence
IDE plugin persistence	Installed JetBrains plugin with listed package ID	Marketplace installation places plugin into user IDE profile	Medium-high
Credential storage	API key saved in plugin settings or IDE configuration	User must enter key into plugin settings for functionality	Medium
Extension persistence	Smart Adblocker and Adblock for Browser Chrome extensions	Reported Chrome Web Store extensions with long-running install base	Medium-high for adjacent context
No reported OS autorun	Services, scheduled tasks, LaunchAgents not described	Public reporting focuses on plugin/extension runtime behavior	Medium

Response teams should remove the malicious plugin/extension and then rotate exposed credentials. Removal alone does not invalidate API keys already exfiltrated before cleanup.

10. Network and Infrastructure Analysis

IOC / Infrastructure	Type	Role	Stability / Confidence
39.107.60[.]51	IP address	Reported attacker-controlled key-exfiltration server	High confidence; stability unknown and may change quickly
JetBrains Marketplace	Distribution channel	Hosted malicious plugin listings	High confidence; marketplace listings may be removed or renamed
OpenAI / DeepSeek / SiliconFlow APIs	Legitimate service APIs	Provider APIs used by plugin functionality and abused credential targets	High confidence for provider scope
Chrome Web Store	Distribution channel for adjacent extensions	Hosted Smart Adblocker and Adblock for Browser according to source reporting	Medium-high for adjacent context

The infrastructure model is low-friction: direct IP exfiltration plus legitimate provider APIs. That simplicity makes a single IP block useful but insufficient. Retroactive exposure scoping should include the plugin installation date, all API keys entered into affected plugins, provider usage and billing anomalies, and any developer-workstation traffic to direct IP infrastructure outside approved AI-provider endpoints.

11. Indicators of Compromise

The available IOC set is small but high-value. Machine-readable indicators are preserved in iocs.csv.

IOC Type	Example / Count	Source	Operational Notes
IP address	1: 39.107.60[.]51	Aikido / The Hacker News reporting	Block and retrohunt; treat direct IDE process egress as high severity
JetBrains plugin ID	15 plugin/package IDs	Aikido / The Hacker News reporting	Inventory developer endpoints and IDE profiles; marketplace removal does not remove local installs
Chrome extension ID	2 extension IDs for adjacent PromptSnatcher activity	The Hacker News / Jean-Marie R. reporting	Review Chrome enterprise extension inventory and AI-chat exposure risk
Provider secret pattern	OpenAI, DeepSeek, SiliconFlow API keys	Source-reported target types	Rotate keys, review billing, and inspect provider usage logs
Type	Value	Description	Confidence
ip	39.107.60[.]51	Reported attacker-controlled API-key exfiltration endpoint	High
jetbrains_plugin_id	org.sm.yms.toolkit	DeepSeek Junit Test	High
jetbrains_plugin_id	com.json.simple.kit	DeepSeek Git Commit	High
jetbrains_plugin_id	org.bug.find.tools	DeepSeek FindBugs	High
jetbrains_plugin_id	org.translate.ai.simple	DeepSeek AI Chat	High
jetbrains_plugin_id	com.yy.test.ai.simple	DeepSeek Dev AI	High
jetbrains_plugin_id	com.dev.ai.toolkit	DeepSeek AI Coding	High
jetbrains_plugin_id	com.json.view.simple	AI FindBugs	High
jetbrains_plugin_id	com.my.git.ai.kit	AI Git Commitor	High
jetbrains_plugin_id	org.check.ai.ds	AI Coder Review	High
jetbrains_plugin_id	com.review.tool.code	DeepSeek Coder AI	High
jetbrains_plugin_id	org.code.assist.dev.tool	AI Coder Assistant	High
jetbrains_plugin_id	com.coder.ai.dpt	DeepSeek Code Review	High
jetbrains_plugin_id	com.my.code.tools	CodeGPT AI Assistant	High
jetbrains_plugin_id	ord.cp.code.ai.kit	DeepSeek AI Assist	High
jetbrains_plugin_id	com.dp.git.ai.tool	Coding Simple Tool	High
chrome_extension_id	iojpcjdfhlcbgjnpngcmaojmlokmeii	Smart Adblocker, adjacent PromptSnatcher reporting	Medium-high
chrome_extension_id	jcbjccocinigpbfgfnhlpagidbmlngnnn	Adblock for Browser, adjacent PromptSnatcher reporting	Medium-high

12. MITRE ATT&CK Mapping

Technique	Name	Evidence
T1195.002	Supply Chain Compromise: Compromise Software Supply Chain	Malicious plugins distributed through JetBrains Marketplace listings
T1199	Trusted Relationship	Developers trust IDE marketplace plugins and grant them access to API keys and IDE context
T1552.001	Unsecured Credentials: Credentials In Files	API keys are entered into and likely stored/read from plugin settings or local IDE configuration
T1056	Input Capture	The malicious plugin captures user-entered API keys through settings workflow; adjacent PromptSnatcher captures AI conversations
T1041	Exfiltration Over C2 Channel	API keys transmitted to attacker-controlled 39.107.60[.]51
T1105	Ingress Tool Transfer	Marketplace plugin installation delivers malicious code into developer workstations
T1036	Masquerading	Plugins masquerade as legitimate DeepSeek/AI coding assistants; Chrome extensions masquerade as ad blockers
T1119	Automated Collection	Adjacent PromptSnatcher extensions reportedly collect AI conversation history and account metadata
T1071.001	Application Layer Protocol: Web Protocols	HTTP used for key exfiltration and normal AI-provider communications

13.1 Detection Logic Summary

Signal	Telemetry Source	Analytic Goal	Tuning Notes
Installed malicious JetBrains plugin ID	Endpoint file inventory, MDM, IDE plugin inventory	Identify exposed developer hosts	Account for OS-specific JetBrains config paths and multiple IDE products
JetBrains IDE egress to 39.107.60.51	EDR network, proxy, firewall, DNS where applicable	Detect source-reported exfiltration endpoint	Direct IP HTTP traffic from IDE processes should be rare
AI-provider key exposure	Secrets scanning, DLP, provider audit logs	Identify keys entered into untrusted tools	Never log raw keys in SIEM; store only redacted fingerprint/hashes
Chrome extension IDs	Browser management inventory	Detect adjacent PromptSnatcher exposure	Separate from JetBrains plugin incident but include in AI-governance sweep
Provider billing anomaly	OpenAI/DeepSeek/SiliconFlow usage logs	Detect post-theft abuse or resale	Baseline by project/team; alert on new geographies, models, or

spikes

13.2 Detection Content

```

title: JetBrains IDE Network Connection To Reported Malicious AI Plugin Exfiltration IP
id: 2382963d-91b4-4dd5-8db2-jetbrains-ai-key-theft
status: experimental
description: Detects JetBrains IDE processes connecting to the IP address reported for malicious AI
plugin API-key exfiltration.
references:
  - https://thehackernews.com/2026/06/malicious-jetbrains-plugins-steal-ai.html
author: Lost Boys Cyber
date: 2026-06-17
logsource:
  category: network_connection
  product: windows
detection:
  selection_process:
    Image|endswith:
      - '\idea64.exe'
      - '\idea.exe'
      - '\pycharm64.exe'
      - '\pycharm.exe'
      - '\webstorm64.exe'
      - '\webstorm.exe'
      - '\goland64.exe'
      - '\rider64.exe'
      - '\clion64.exe'
      - '\datagrip64.exe'
  selection_destination:
    DestinationIp: '39.107.60.51'
  condition: selection_process and selection_destination
falsepositives:
  - Security research or controlled validation using the reported endpoint
level: high

// Microsoft Defender XDR: JetBrains IDE egress to reported exfiltration IP
DeviceNetworkEvents
| where Timestamp > ago(90d)
| where RemoteIP == "39.107.60.51"
| where InitiatingProcessFileName in~ ("idea64.exe", "idea.exe", "pycharm64.exe", "pycharm.exe",
"webstorm64.exe", "webstorm.exe", "goland64.exe", "rider64.exe", "clion64.exe", "datagrip64.exe")
| project Timestamp, DeviceName, InitiatingProcessAccountName, InitiatingProcessFileName,
InitiatingProcessCommandLine, RemoteIP, RemotePort, Protocol, ReportId

// Microsoft Defender XDR: suspicious JetBrains plugin identifiers on developer endpoints
DeviceFileEvents
| where Timestamp > ago(90d)
| where FolderPath has_any ("JetBrains", ".IntelliJIdea", ".PyCharm", ".WebStorm", ".GoLand", ".Rider",
".CLion", ".DataGrip")
| where FolderPath has_any ("org.sm.ym.s.toolkit", "com.json.simple.kit", "org.bug.find.tools",
"org.translate.ai.simple", "com.yy.test.ai.simple", "com.dev.ai.toolkit", "com.json.view.simple",
"com.my.git.ai.kit", "org.check.ai.ds", "com.review.tool.code", "org.code.assist.dev.tool",
"com.coder.ai.dpt", "com.my.code.tools", "ord.cp.code.ai.kit", "com.dp.git.ai.tool")
| project Timestamp, DeviceName, ActionType, FolderPath, FileName, SHA256, InitiatingProcessFileName,
InitiatingProcessAccountName

index=edr sourcetype=network
(dest_ip="39.107.60.51" OR remote_ip="39.107.60.51")
(process_name IN
("idea64.exe", "idea.exe", "pycharm64.exe", "pycharm.exe", "webstorm64.exe", "webstorm.exe", "goland64.exe", "
rider64.exe", "clion64.exe", "datagrip64.exe"))
| stats min(_time) as first_seen max(_time) as last_seen count by host user process_name process_path
dest_ip dest_port
| convert ctime(first_seen) ctime(last_seen)

rule Suspicious_JetBrains_AI_Plugin_Key_Theft_Strings
{
  meta:

```

```

description = "Hunts JetBrains plugin archives or decompiled classes for strings associated
with the reported AI API-key theft campaign"
author = "Lost Boys Cyber"
date = "2026-06-17"
confidence = "medium"
caveat = "String-only hunting rule; validate with decompilation and network telemetry"
strings:
    $ip = "39.107.60.51" ascii wide
    $p1 = "OpenAI" ascii wide nocase
    $p2 = "SiliconFlow" ascii wide nocase
    $p3 = "DeepSeek" ascii wide nocase
    $h1 = "URLConnection" ascii wide
    $h2 = "OkHttp" ascii wide
    $h3 = "http://" ascii wide
condition:
    $ip or (2 of ($p*) and any of ($h*))
}

```

13.3 Detection Validation and Blind Spots

Validate the network analytic by confirming the endpoint had a JetBrains IDE installed, the user had one of the listed plugins installed or recently removed, and the connection timestamp aligns with plugin settings changes or IDE startup. Validate file/plugin inventory hits by matching plugin IDs, marketplace listing names, and install timestamps. Blind spots include non-Windows developer endpoints, renamed IDE processes, proxy logs that do not preserve initiating process, variants using domains or different IPs, and local plugin remnants removed before inventory collection.

14.1 Hunt Hypotheses

- A developer installed one of the listed JetBrains AI-assistant plugins and the IDE made direct HTTP egress to the reported exfiltration IP.
- AI-provider API keys entered into IDE plugins were abused after exfiltration, causing unusual usage, model calls, geography, or billing spikes.
- Chrome users with the two reported ad-blocker extension IDs may have exposed non-public AI-chat prompts, model usage, or subscription-tier metadata.
- Similar marketplace copycats may use the same naming pattern, provider-key workflow, and direct-IP HTTP exfiltration even if the exact plugin ID differs.

14.2 Hunt Queries

```

// Hunt 1: Developer endpoints with listed JetBrains plugin IDs in filesystem telemetry
let BadPluginIds = dynamic([
    "org.sm.yms.toolkit", "com.json.simple.kit", "org.bug.find.tools", "org.translate.ai.simple",
    "com.yy.test.ai.simple",
    "com.dev.ai.toolkit", "com.json.view.simple", "com.my.git.ai.kit", "org.check.ai.ds",
    "com.review.tool.code",
    "org.code.assist.dev.tool", "com.coder.ai.dpt", "com.my.code.tools", "ord.cp.code.ai.kit",
    "com.dp.git.ai.tool"
]);
DeviceFileEvents
| where Timestamp > ago(180d)
| where FolderPath has_any (BadPluginIds) or FileName has_any (BadPluginIds)
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Actions=make_set(ActionType, 10),
Paths=make_set(FolderPath, 20) by DeviceName, InitiatingProcessAccountName

// Hunt 2: JetBrains IDEs making direct-IP HTTP connections outside expected AI-provider infrastructure
DeviceNetworkEvents
| where Timestamp > ago(90d)
| where InitiatingProcessFileName has_any ("idea", "pycharm", "webstorm", "goland", "rider", "clion",
"datagrip")
| where RemotePort in (80, 8080) or Protocol =~ "Http"
| where isnotempty(RemoteIP) and RemoteUrl == ""
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Count=count(),
RemotePorts=make_set(RemotePort, 10) by DeviceName, InitiatingProcessAccountName,
InitiatingProcessFileName, RemoteIP
| order by Count desc

```

```
// Hunt 3: Reported Chrome extension IDs in browser extension inventory exported to device events or software inventory
DeviceTvmSoftwareInventory
| where SoftwareName has_any ("Smart Adblocker", "Adblock for Browser") or SoftwareVersion has_any ("iojpcjjdfhlcbgjnpgcmajmlokmeii", "jcbjcocinigpbgfphlpagidbmlngnnn")
| project DeviceName, SoftwareName, SoftwareVersion, EndOfSupportStatus, EndOfSupportDate
index=proxy OR index=edr
("39.107.60.51" OR "org.sm.yms.toolkit" OR "com.my.code.tools" OR "ord.cp.code.ai.kit")
| eval indicator=case(match(_raw,"39\107\60\51"),"reported_exfil_ip",
match(_raw,"org\sm\yms\toolkit|com\my\code\tools|ord\cp\code\ai\kit"),"reported_plugin_id",
true(),"other")
| stats min(_time) as first_seen max(_time) as last_seen count values(indicator) as indicators
values(process_name) as processes values(url) as urls by host user
| convert ctime(first_seen) ctime(last_seen)
```

14.3 Triage Guidance for Hunt Hits

A meaningful hit is any developer workstation with a listed plugin ID, any JetBrains IDE process connecting to 39.107.60[.]51, or any AI-provider billing anomaly tied to keys known to have been entered into those plugins. Escalate to incident response when network telemetry confirms egress to the reported IP or when exposed API keys show unexplained usage after the exposure window. Benign lookalikes include legitimate JetBrains AI plugins, approved internal AI assistants, developer testing of HTTP clients, and security research into the campaign.

15. Triage and Incident Response

Priority	Action	Owner	Rationale
Critical	Remove or disable listed JetBrains plugins from developer endpoints	Endpoint / Engineering IT	Stops additional exposure through known malicious plugins
Critical	Revoke and rotate AI-provider API keys entered into affected plugins	Engineering owners / AI platform owners	Exfiltrated keys remain usable after plugin removal
High	Review OpenAI, DeepSeek, and SiliconFlow usage and billing logs	AI platform owners / Finance / SecOps	Detect LLMjacking, resale, or unauthorized model usage
High	Retrospectively hunt 39.107.60[.]51 and listed plugin IDs for 180 days	SecOps	Activity reportedly dates to late October 2025; local telemetry retention determines lookback
High	Preserve IDE plugin directories and relevant proxy/EDR logs for confirmed hosts	IR / Forensics	Enables validation without exposing raw API keys in tickets
Medium	Review Chrome extension inventory for PromptSnatcher IDs	Browser / Endpoint admins	Adjacent AI-chat privacy exposure may affect the same developer population
Medium	Implement allowlisted IDE/browser extension governance	Security architecture / Engineering leadership	Prevents recurrence through marketplace trust abuse

Incident scope should include the user account, host, IDE profile, repositories accessed during exposure, provider keys entered into the plugin, and any CI/CD or cloud credentials present on the developer workstation. Do not paste raw API keys into case notes or SIEM queries.

16. Validation and Emulation

Validation Area	Status	Evidence
Source retrieval	Completed	The Hacker News article text was retrieved and parsed locally; search results corroborated Aikido/BleepingComputer/Hackread/Cyber Press coverage
Plugin sample detonation	Not completed	No plugin archive or controlled JetBrains lab sample was provided
Static reverse engineering	Not completed	No raw plugin JAR/package was available for decompilation
Detection logic	Drafted, source-backed	Queries target reported plugin IDs, process names, extension IDs, and 39.107.60[.]51
IOC sidecar	Completed	iocs.csv populated with IP, plugin IDs, Chrome extension IDs, and provider-secret targets

Safe emulation guidance:

- Do not use production API keys for validation.
- Build a disposable VM with a clean JetBrains IDE profile and no production repositories.
- If a plugin package is obtained, install it offline or in an isolated network segment first, then repeat with INetSim or a controlled HTTP capture endpoint if the code can be safely redirected.
- Use a fake provider key with a unique marker string and confirm whether any outbound request contains it.
- Capture process, file, and network telemetry; do not contact attacker infrastructure unless approved for controlled research.
- For Chrome extension validation, use a disposable browser profile and test prompt data that contains no client or proprietary content.

17. Recommendations

Priority	Owner	Action	Rationale
Critical	Engineering leadership / SecOps	Immediately inventory and remove the 15 listed JetBrains plugin IDs	Known malicious plugin exposure is a direct secret-theft risk
Critical	AI platform owners	Rotate OpenAI, DeepSeek, and SiliconFlow keys entered into any untrusted IDE plugin	Assume keys entered into listed plugins are compromised
High	SecOps	Add proxy/EDR detections for JetBrains IDE egress to 39.107.60[.]51 and direct-IP HTTP	Detects the reported exfiltration behavior and possible variants
High	Finance / AI platform owners	Review provider billing and usage logs for spikes, unfamiliar geographies, new models, and unusual hours	Stolen keys may be monetized through LLMjacking
High	Endpoint / Browser admins	Enforce allowlists for JetBrains	Marketplace abuse will recur;

		plugins and Chrome extensions used by developers	governance must precede install time
Medium	AppSec / DevSecOps	Add developer-tool extensions to software supply-chain review scope	IDE plugins and browser extensions can access sensitive development workflows
Medium	Detection engineering	Convert the draft Sigma/KQL/SPL/YARA content into environment-specific analytics and test against known-good developer hosts	Reduces noise and improves operational readiness
Medium	Security awareness	Brief developers on AI plugin risks and the policy for entering long-lived API keys into third-party tools	The credential-entry step appears normal, so policy clarity is required

18. References and Refresh Notes

- [1] The Hacker News, "Malicious JetBrains Plugins Steal AI API Keys as Chrome Extensions Capture Chatbot Chats," published 2026-06-17, <https://thehackernews.com/2026/06/malicious-jetbrains-plugins-steal-ai.html>
- [2] Aikido Security, "Multiple JetBrains IDE plugins caught stealing AI keys," referenced by The Hacker News and search-result summaries, <https://www.aikido.dev/blog/multiple-jetbrains-ide-plugins-caught-stealing-ai-keys>
- [3] BleepingComputer, "Malicious JetBrains Marketplace plugins steal AI API keys from developers," search-result corroboration, <https://www.bleepingcomputer.com/news/security/malicious-jetbrains-marketplace-plugins-steal-ai-api-keys-from-developers/>
- [4] Hackread, "15 Malicious JetBrains Plugins Caught Stealing DeepSeek, OpenAI API Keys," search-result corroboration, <https://hackread.com/malicious-jetbrains-plugins-steal-deepseek-openai-api-keys/>
- [5] CyberPress, "Malicious JetBrains Plugins Caught Harvesting AI API Keys from Developers," search-result corroboration, <https://cyberpress.org/malicious-jetbrains-plugins/>
- [6] MITRE ATT&CK Enterprise Matrix, techniques referenced in this report, <https://attack.mitre.org/>

Refresh notes: marketplace listings, install counts, vendor accounts, and exfiltration infrastructure can change quickly. Before operational use, refresh JetBrains Marketplace status, confirm whether the plugins have been removed, obtain raw plugin archives where lawful, and verify whether 39.107.60[.]51 remains active or has been replaced by domains or new IPs. For PromptSnatcher, refresh Chrome Web Store status and extension permissions before client notification.